

Azure Compliance Implementation Checklist

Document:	Azure Config Snapshot (2025-11-26T11:28:28.042000)
Frameworks:	ISO27018
Total Items:	5
Generated:	2025-11-26 19:15:08 UTC

Item #1: Implement Consent Management Framework for PII Processing

Priority: CRITICAL

Effort: Complex

Description:

Establish a system for obtaining, recording, and managing user consent for PII processing. This includes defining consent types, mechanisms for obtaining consent, and a central repository for managing consent records.

Gap Addressed: Lack of explicit consent management procedures for PII processing in the cloud environment.

Azure Portal Navigation: Azure Portal > Azure Active Directory > App registrations > New registration

Settings to Configure:

Setting Name:	N/A
Current Value:	N/A
Required Value:	N/A
Location:	Azure Active Directory App Registration

Step-by-Step Implementation Guide:

Step 1: Register a new application in Azure Active Directory

Navigate to Azure Portal > Azure Active Directory > App registrations > New registration. Enter 'ConsentManagementApp' as the name, select 'Accounts in this organizational directory only (Single tenant)' for supported account types, and enter 'https://consentmanagement.example.com/callback' as the redirect URI (replace with your actual callback URL).

What to look for: You should see the 'Register an application' page with the specified settings.

Step 2: Configure API Permissions for the ConsentManagementApp

Navigate to the newly created app registration. Go to 'API permissions' > 'Add a permission'. Select 'Microsoft Graph' > 'Delegated permissions'. Add the following permissions: 'User.Read', 'User.ReadBasic.All', 'openid', 'profile', 'email'. Grant admin consent for these permissions.

What to look for: You should see the list of API permissions with the granted status.

Step 3: Create an Azure Cosmos DB database and container to store consent records

Navigate to Azure Portal > Azure Cosmos DB > Create. Create a new database named 'ConsentDB' and a container named 'ConsentRecords' with a partition key of '/userId'.

What to look for: You should see the newly created database and container in Azure Cosmos DB.

Step 4: Develop an Azure Logic App to handle consent requests and updates

Create a new Azure Logic App that triggers on HTTP requests. The Logic App should: 1) Authenticate users using Azure AD. 2) Present consent options to the user. 3) Store the user's consent choices in the Azure Cosmos DB container. 4) Update user attributes in Azure AD based on consent (e.g., custom attributes).

What to look for: You should see the Logic App designer with the configured triggers and actions.

Step 5: Store the ConsentManagementApp's client secret in Azure Key Vault

Navigate to Azure Portal > Key Vault > Create. Create a new Key Vault and store the ConsentManagementApp's client secret as a secret named 'ConsentAppSecret'. Grant the Logic App managed identity access to read the secret.

What to look for: You should see the newly created Key Vault and the stored secret.

Verification Steps:

- Step 1: Access the Consent Management application and verify that you are prompted to grant consent for the requested permissions.
- Step 2: Check the Azure Cosmos DB container to ensure that your consent choices are recorded correctly.
- Step 3: Verify that your user attributes in Azure AD are updated based on your consent choices.

Azure Services Required: Azure Active Directory, Azure Logic Apps, Azure Cosmos DB, Azure Key Vault

Expected Outcome: Establishes a mechanism for obtaining, recording, and managing user consent for PII processing, aligning with ISO 27018 requirements.

Framework Reference: ISO 27018:2019 8.1.2

Additional Notes: Ensure the ConsentManagementApp is properly secured and that access to the Azure Cosmos DB and Key Vault is restricted to authorized services and personnel.

Item #2: Implement Data Subject Rights (DSR) Request Handling Procedures

Priority:

CRITICAL

Effort:

Complex

Description:

Develop and document procedures for handling data subject rights requests (access, rectification, erasure, portability). This includes defining roles and responsibilities, establishing timelines for responding to requests, and implementing mechanisms for verifying the identity of the requestor.

Gap Addressed: Absence of documented processes for handling data subject rights requests (access, rectification, erasure, portability) as required by ISO 27018:2019.

Azure Portal Navigation: Azure Portal > Azure Logic Apps > Create

Settings to Configure:

Setting Name:	N/A
Current Value:	N/A
Required Value:	N/A
Location:	Azure Logic Apps

Step-by-Step Implementation Guide:

Step 1: Create an Azure Logic App to process DSR requests

Navigate to Azure Portal > Azure Logic Apps > Create. Create a new Logic App named 'DSRRequestProcessor' that triggers on HTTP requests. Configure the trigger to accept JSON payloads containing the request type (access, rectification, erasure, portability), user ID, and other relevant information.

What to look for: You should see the Logic App designer with the HTTP Request trigger configured.

Step 2: Implement identity verification using Azure Active Directory

Within the Logic App, add an action to authenticate the user making the request using Azure Active Directory. This can be achieved by integrating with Azure AD's authentication endpoints and verifying the user's identity based on their credentials.

What to look for: You should see the Azure AD authentication action configured in the Logic App.

Step 3: Create Azure Functions to handle specific DSR request types

Create separate Azure Functions for each DSR request type (access, rectification, erasure, portability). Each function should: 1) Authenticate the request. 2) Retrieve or modify the user's data from relevant Azure services (e.g., Azure Cosmos DB, Azure SQL Database). 3) Return the requested data or confirm the completion of the request.

What to look for: You should see the Azure Functions created and configured to handle specific DSR request types.

Step 4: Store DSR request logs in Azure Storage

Create an Azure Storage account and configure a blob container to store DSR request logs. The Logic App should write logs to this container for auditing and compliance purposes. Include details such as the request type, user ID, timestamp, and status of the request.

What to look for: You should see the Azure Storage account and blob container created, and the Logic App configured to write logs to the container.

Step 5: Configure the Logic App to call the appropriate Azure Function based on the request type

Within the Logic App, add a 'Switch' control that routes the request to the appropriate Azure Function based on the 'requestType' field in the JSON payload. Configure each case in the Switch control to call the corresponding Azure Function.

What to look for: You should see the Switch control configured in the Logic App, with each case calling the appropriate Azure Function.

Verification Steps:

- Step 1: Submit a DSR request through the Logic App's HTTP endpoint.
- Step 2: Verify that the request is processed correctly by checking the Azure Function logs.
- Step 3: Confirm that the user's data is retrieved, modified, or deleted as requested.
- Step 4: Check the Azure Storage container to ensure that the DSR request log is created.

Azure Services Required: Azure Logic Apps, Azure Functions, Azure Storage, Azure Active Directory

Expected Outcome: Establishes a documented and automated process for handling data subject rights requests, aligning with ISO 27018 requirements.

Framework Reference: ISO 27018:2019 8.2.1

Additional Notes: Ensure that the Azure Functions are properly secured and that access to the Azure Storage account is restricted to authorized services and personnel. Regularly review and update the DSR request handling procedures to ensure compliance with evolving regulations.

Item #4: Implement PII Breach Notification Procedures

Priority:

CRITICAL

Effort:

Complex

Description:

Establish specific procedures for PII breach notification, including timelines and communication channels, as mandated by ISO 27018:2019. This includes defining roles and responsibilities, establishing a breach response team, and creating a communication plan.

Gap Addressed: No specific procedures for PII breach notification, including timelines and communication channels, as mandated by ISO 27018:2019.

Azure Portal Navigation: Azure Portal > Azure Security Center > Security alerts

Settings to Configure:

Setting Name:	N/A
Current Value:	N/A
Required Value:	N/A
Location:	Azure Security Center

Step-by-Step Implementation Guide:

Step 1: Configure Azure Security Center to detect potential PII breaches

Navigate to Azure Portal > Azure Security Center > Security alerts. Enable and configure relevant security alerts that can indicate a potential PII breach, such as alerts for suspicious activity, data exfiltration, and unauthorized access. Configure alert suppression rules to reduce noise and focus on critical alerts.

What to look for: You should see the list of security alerts and the configured alert suppression rules.

Step 2: Create Azure Monitor alert rules to detect specific PII breach scenarios

Navigate to Azure Portal > Azure Monitor > Alerts > Create alert rule. Create alert rules that trigger on specific events or metrics that indicate a potential PII breach, such as excessive data access, unusual network traffic, and failed authentication attempts. Configure the alert rules to send notifications to the breach response team.

What to look for: You should see the list of alert rules and the configured notification settings.

Step 3: Develop an Azure Logic App to automate the PII breach notification process

Create a new Azure Logic App that triggers on Azure Security Center alerts or Azure Monitor alerts. The Logic App should: 1) Gather relevant information about the breach. 2) Notify the breach response team via email, SMS, or other communication channels. 3) Initiate incident response procedures, such as isolating affected systems and preserving evidence.

What to look for: You should see the Logic App designer with the configured triggers and actions.

Step 4: Create an Azure Automation runbook to automate incident response tasks

Create an Azure Automation runbook that performs automated incident response tasks, such as isolating affected systems, disabling compromised accounts, and collecting forensic data. The Logic App should call the runbook when a PII breach is detected.

What to look for: You should see the Azure Automation runbook created and configured to perform incident response tasks.

Step 5: Document the PII breach notification procedures

Document the PII breach notification procedures, including roles and responsibilities, timelines for notification, communication channels, and escalation paths. Ensure that the procedures are regularly

reviewed and updated.

What to look for: You should have a well-documented PII breach notification procedure that is readily available to the breach response team.

Verification Steps:

- Step 1: Simulate a PII breach scenario and verify that the Azure Security Center and Azure Monitor alerts are triggered.
- Step 2: Check that the Azure Logic App is triggered and that the breach response team is notified.
- Step 3: Verify that the Azure Automation runbook is executed and that the incident response tasks are performed.
- Step 4: Review the PII breach notification procedures to ensure that they are followed correctly.

Azure Services Required: Azure Security Center, Azure Monitor, Azure Logic Apps, Azure Automation

Expected Outcome: Establishes a documented and automated process for PII breach notification, aligning with ISO 27018 requirements.

Framework Reference: ISO 27018:2019 8.4.1

Additional Notes: Regularly test the PII breach notification procedures to ensure that they are effective. Consider engaging a third-party security expert to review and validate the procedures.

Item #3: Implement Transparency Reporting for PII Processing

Priority:

HIGH

Effort:

Moderate

Description:

Establish a mechanism for informing data subjects about the purposes of processing, categories of data processed, and recipients of the data. This includes creating a privacy notice and making it easily accessible to data subjects.

Gap Addressed: No mention of transparency requirements related to PII processing, including informing data subjects about the purposes of processing, categories of data processed, and recipients of the data.

Azure Portal Navigation: Azure Portal > Storage accounts > Create

Settings to Configure:

Setting Name:	N/A
Current Value:	N/A
Required Value:	N/A
Location:	Azure Storage

Step-by-Step Implementation Guide:

Step 1: Create an Azure Storage account to host the privacy notice

Navigate to Azure Portal > Storage accounts > Create. Create a new Storage account named 'piitransparencystorage' with the 'StorageV2 (general purpose v2)' account kind and 'Hot' access tier. Enable static website hosting for the storage account.

What to look for: You should see the newly created Storage account with static website hosting enabled.

Step 2: Create a privacy notice document

Create a clear and concise privacy notice document that explains the purposes of PII processing, the categories of data processed, and the recipients of the data. Include information about data subject rights and how to exercise them.

What to look for: You should have a well-written privacy notice document that is easy to understand.

Step 3: Upload the privacy notice document to the Azure Storage account

Upload the privacy notice document to the '\$web' container in the Azure Storage account. Ensure that the document is publicly accessible.

What to look for: You should see the privacy notice document in the '\$web' container of the Azure Storage account.

Step 4: Configure Azure CDN to improve the performance and availability of the privacy notice

Navigate to Azure Portal > CDN profiles > Create. Create a new CDN profile and endpoint that points to the Azure Storage account's static website endpoint. Configure caching rules to optimize performance.

What to look for: You should see the CDN profile and endpoint created, and the CDN endpoint pointing to the Azure Storage account.

Step 5: Link to the privacy notice from all relevant applications and websites

Add a link to the privacy notice (using the CDN endpoint URL) from all applications and websites that process PII. Ensure that the link is prominently displayed and easily accessible to data subjects.

What to look for: You should see the link to the privacy notice on all relevant applications and websites.

Verification Steps:

- Step 1: Access the privacy notice through the CDN endpoint URL.
- Step 2: Verify that the privacy notice document is displayed correctly.
- Step 3: Check that the link to the privacy notice is visible and accessible on all relevant applications and websites.

Azure Services Required: Azure Storage, Azure CDN, Azure App Service

Expected Outcome: Provides data subjects with clear and accessible information about PII processing practices, aligning with ISO 27018 requirements.

Framework Reference: ISO 27018:2019 8.3.1

Additional Notes: Regularly review and update the privacy notice to ensure that it accurately reflects current PII processing practices. Consider translating the privacy notice into multiple languages to cater to a diverse user base.

Item #5: Define PII Retention Period and Destruction Procedures

Priority:

HIGH

Effort:

Moderate

Description:

Explicitly address the retention period for PII before its destruction after termination of a contract, as required by ISO 27018:2019. This includes defining retention policies, implementing data destruction methods, and documenting the destruction process.

Gap Addressed: The document does not explicitly address the retention period for PII before its destruction after termination of a contract, as required by ISO 27018:2019.

Azure Portal Navigation: Azure Portal > Azure Policy > Definitions > Create policy definition

Settings to Configure:

Setting Name:	N/A
Current Value:	N/A
Required Value:	N/A
Location:	Azure Policy

Step-by-Step Implementation Guide:

Step 1: Define PII retention policies for each type of PII

Define clear and specific retention policies for each type of PII, taking into account legal and regulatory requirements, as well as business needs. Specify the retention period, the trigger for data destruction (e.g., contract termination, user request), and the data destruction method.

What to look for: You should have a documented set of PII retention policies that are aligned with legal and regulatory requirements.

Step 2: Implement data destruction methods for each type of PII

Implement appropriate data destruction methods for each type of PII, ensuring that the data is securely and permanently erased. This may involve using data wiping tools, cryptographic erasure, or physical destruction of storage media.

What to look for: You should have a documented set of data destruction methods that are appropriate for each type of PII.

Step 3: Automate the data destruction process using Azure services

Use Azure services such as Azure Logic Apps, Azure Functions, and Azure Automation to automate the data destruction process. Configure these services to trigger data destruction based on the defined retention policies and to log the destruction process for auditing purposes.

What to look for: You should see the Azure services configured to automate the data destruction process.

Step 4: Implement Azure Policy to enforce PII retention policies

Navigate to Azure Portal > Azure Policy > Definitions > Create policy definition. Create Azure Policy definitions to enforce PII retention policies. These policies can be used to identify resources that contain PII and to ensure that data destruction is performed according to the defined retention policies.

What to look for: You should see the Azure Policy definitions created and assigned to the relevant scopes.

Step 5: Document the data destruction process

Document the data destruction process, including the retention policies, the data destruction methods, the Azure services used, and the logging procedures. Ensure that the documentation is regularly

reviewed and updated.

What to look for: You should have a well-documented data destruction process that is readily available to authorized personnel.

Verification Steps:

- Step 1: Verify that the data destruction process is triggered according to the defined retention policies.
- Step 2: Check that the data is securely and permanently erased using the appropriate data destruction methods.
- Step 3: Review the data destruction logs to ensure that the process is performed correctly.
- Step 4: Use Azure Policy to identify resources that are not compliant with the PII retention policies.

Azure Services Required: Azure Storage, Azure SQL Database, Azure Cosmos DB, Azure Data Lake Storage

Expected Outcome: Ensures that PII is retained only for the defined retention period and is securely destroyed after termination of a contract, aligning with ISO 27018 requirements.

Framework Reference: ISO 27018:2019 8.5.1

Additional Notes: Regularly review and update the PII retention policies and data destruction procedures to ensure that they are aligned with legal and regulatory requirements. Consider engaging a third-party security expert to review and validate the procedures.